

AI SECURITY

Hands-On Practice Report

OWASP Top 10 for LLM Applications (2025) — Week 3 Practical Log

Prepared by: _____

Date Range: _____

Roadmap Stage: AI Security — Week 3, Phase 3

Purpose of This Report

This report documents hands-on exercises performed against each of the ten risks in the OWASP Top 10 for LLM Applications (2025 edition). For each risk, this report records: the exercise performed, the exact steps taken, what was observed, the underlying root cause, and the mitigation that would address it. This mirrors the structure of a real AI security assessment / red-team log, and is intended as both a learning record and a portfolio artifact.

How to Use This Template

- 1. Complete one risk section per session — don't rush all ten at once.
- 2. Fill in the blank fields directly in this document, or copy the structure into your own notes.
- 3. Be specific in "Steps Taken" — exact prompts/actions, not just "tried a few things."
- 4. The Confidence Rating row at the end of each section is for your own self-assessment before moving to the next risk.

Summary Tracker

Fill in as you complete each section. Use this as an at-a-glance progress view.

Risk	Exercise Platform	Date Done	Status
LLM01	Gandalf (gandalf.lakera.ai) / PortSwigger		Not started / Done
LLM02	DIY session-isolation exercise		Not started / Done
LLM03	Hugging Face model card audit / OAuth inventory		Not started / Done
LLM04	DIY backdoor-trigger thought experiment		Not started / Done
LLM05	PromptTrace / markdown image test		Not started / Done
LLM06	PromptTrace (Tool Exploitation) / permission mapping		Not started / Done
LLM07	Gandalf (reframed) / multi-product extraction test		Not started / Done
LLM08	PromptTrace (RAG Poisoning)		Not started / Done
LLM09	DIY citation-verification exercise		Not started / Done
LLM10	DIY token/cost & loop-cap exercise		Not started / Done

LLM01 — Prompt Injection

Exercise Platform / Method	Gandalf (gandalf.lakera.ai) / PortSwigger
Date Completed	
Time Spent	

1. Objective

What were you trying to demonstrate or extract in this exercise?

2. Steps Taken

Log each attempt/prompt/action in order. Include exact phrasing where relevant.

Attempt 1:

Attempt 2:

Attempt 3:

Attempt 4:

3. Observations / Result

What actually happened? Did it succeed, partially succeed, or fail? Include anything surprising.

4. Root Cause (map to the mechanism, not just the symptom)

5. Mitigation You Would Recommend

Be specific — name the layer (input/architecture/output/governance), not just "add security."

6. Confidence Rating

Explain to someone else	Demonstrated hands-on	Know 2+ real mitigations
-------------------------	-----------------------	--------------------------

LLM02 — Sensitive Information Disclosure

Exercise Platform / Method	DIY session-isolation exercise
Date Completed	
Time Spent	

1. Objective

What were you trying to demonstrate or extract in this exercise?

2. Steps Taken

Log each attempt/prompt/action in order. Include exact phrasing where relevant.

Attempt 1:

Attempt 2:

Attempt 3:

Attempt 4:

3. Observations / Result

What actually happened? Did it succeed, partially succeed, or fail? Include anything surprising.

4. Root Cause (map to the mechanism, not just the symptom)

5. Mitigation You Would Recommend

Be specific — name the layer (input/architecture/output/governance), not just "add security."

6. Confidence Rating

Explain to someone else	Demonstrated hands-on	Know 2+ real mitigations
-------------------------	-----------------------	--------------------------

LLM03 — Supply Chain

Exercise Platform / Method	Hugging Face model card audit / OAuth inventory
Date Completed	
Time Spent	

1. Objective

What were you trying to demonstrate or extract in this exercise?

2. Steps Taken

Log each attempt/prompt/action in order. Include exact phrasing where relevant.

Attempt 1:

Attempt 2:

Attempt 3:

Attempt 4:

3. Observations / Result

What actually happened? Did it succeed, partially succeed, or fail? Include anything surprising.

4. Root Cause (map to the mechanism, not just the symptom)

5. Mitigation You Would Recommend

Be specific — name the layer (input/architecture/output/governance), not just "add security."

6. Confidence Rating

Explain to someone else	Demonstrated hands-on	Know 2+ real mitigations
-------------------------	-----------------------	--------------------------

LLM04 — Data and Model Poisoning

Exercise Platform / Method	DIY backdoor-trigger thought experiment
Date Completed	
Time Spent	

1. Objective

What were you trying to demonstrate or extract in this exercise?

2. Steps Taken

Log each attempt/prompt/action in order. Include exact phrasing where relevant.

Attempt 1:

Attempt 2:

Attempt 3:

Attempt 4:

3. Observations / Result

What actually happened? Did it succeed, partially succeed, or fail? Include anything surprising.

4. Root Cause (map to the mechanism, not just the symptom)

5. Mitigation You Would Recommend

Be specific — name the layer (input/architecture/output/governance), not just "add security."

6. Confidence Rating

Explain to someone else	Demonstrated hands-on	Know 2+ real mitigations
-------------------------	-----------------------	--------------------------

LLM05 — Improper Output Handling

Exercise Platform / Method	PromptTrace / markdown image test
Date Completed	
Time Spent	

1. Objective

What were you trying to demonstrate or extract in this exercise?

2. Steps Taken

Log each attempt/prompt/action in order. Include exact phrasing where relevant.

Attempt 1:

Attempt 2:

Attempt 3:

Attempt 4:

3. Observations / Result

What actually happened? Did it succeed, partially succeed, or fail? Include anything surprising.

4. Root Cause (map to the mechanism, not just the symptom)

5. Mitigation You Would Recommend

Be specific — name the layer (input/architecture/output/governance), not just "add security."

6. Confidence Rating

Explain to someone else	Demonstrated hands-on	Know 2+ real mitigations
-------------------------	-----------------------	--------------------------

LLM06 — Excessive Agency

Exercise Platform / Method	PromptTrace (Tool Exploitation) / permission mapping
Date Completed	
Time Spent	

1. Objective

What were you trying to demonstrate or extract in this exercise?

2. Steps Taken

Log each attempt/prompt/action in order. Include exact phrasing where relevant.

Attempt 1:

Attempt 2:

Attempt 3:

Attempt 4:

3. Observations / Result

What actually happened? Did it succeed, partially succeed, or fail? Include anything surprising.

4. Root Cause (map to the mechanism, not just the symptom)

5. Mitigation You Would Recommend

Be specific — name the layer (input/architecture/output/governance), not just "add security."

6. Confidence Rating

Explain to someone else	Demonstrated hands-on	Know 2+ real mitigations
-------------------------	-----------------------	--------------------------

LLM07 — System Prompt Leakage

Exercise Platform / Method	Gandalf (reframed) / multi-product extraction test
Date Completed	
Time Spent	

1. Objective

What were you trying to demonstrate or extract in this exercise?

2. Steps Taken

Log each attempt/prompt/action in order. Include exact phrasing where relevant.

Attempt 1:

Attempt 2:

Attempt 3:

Attempt 4:

3. Observations / Result

What actually happened? Did it succeed, partially succeed, or fail? Include anything surprising.

4. Root Cause (map to the mechanism, not just the symptom)

5. Mitigation You Would Recommend

Be specific — name the layer (input/architecture/output/governance), not just "add security."

6. Confidence Rating

Explain to someone else	Demonstrated hands-on	Know 2+ real mitigations
-------------------------	-----------------------	--------------------------

LLM08 — Vector and Embedding Weaknesses

Exercise Platform / Method	PromptTrace (RAG Poisoning)
Date Completed	
Time Spent	

1. Objective

What were you trying to demonstrate or extract in this exercise?

2. Steps Taken

Log each attempt/prompt/action in order. Include exact phrasing where relevant.

Attempt 1:

Attempt 2:

Attempt 3:

Attempt 4:

3. Observations / Result

What actually happened? Did it succeed, partially succeed, or fail? Include anything surprising.

4. Root Cause (map to the mechanism, not just the symptom)

5. Mitigation You Would Recommend

Be specific — name the layer (input/architecture/output/governance), not just "add security."

6. Confidence Rating

Explain to someone else	Demonstrated hands-on	Know 2+ real mitigations
-------------------------	-----------------------	--------------------------

LLM09 — Misinformation

Exercise Platform / Method	DIY citation-verification exercise
Date Completed	
Time Spent	

1. Objective

What were you trying to demonstrate or extract in this exercise?

2. Steps Taken

Log each attempt/prompt/action in order. Include exact phrasing where relevant.

Attempt 1:

Attempt 2:

Attempt 3:

Attempt 4:

3. Observations / Result

What actually happened? Did it succeed, partially succeed, or fail? Include anything surprising.

4. Root Cause (map to the mechanism, not just the symptom)

5. Mitigation You Would Recommend

Be specific — name the layer (input/architecture/output/governance), not just "add security."

6. Confidence Rating

Explain to someone else	Demonstrated hands-on	Know 2+ real mitigations
-------------------------	-----------------------	--------------------------

LLM10 — Unbounded Consumption

Exercise Platform / Method	DIY token/cost & loop-cap exercise
Date Completed	
Time Spent	

1. Objective

What were you trying to demonstrate or extract in this exercise?

2. Steps Taken

Log each attempt/prompt/action in order. Include exact phrasing where relevant.

Attempt 1:

Attempt 2:

Attempt 3:

Attempt 4:

3. Observations / Result

What actually happened? Did it succeed, partially succeed, or fail? Include anything surprising.

4. Root Cause (map to the mechanism, not just the symptom)

5. Mitigation You Would Recommend

Be specific — name the layer (input/architecture/output/governance), not just "add security."

6. Confidence Rating

Explain to someone else	Demonstrated hands-on	Know 2+ real mitigations
-------------------------	-----------------------	--------------------------

Overall Reflection

Which risk was hardest to actually demonstrate, and why?

Which risk surprised you the most once you tried it hands-on vs. just reading about it?

Which mitigation pattern showed up across the most risks?

What would you want to explore further in Week 4 (Enterprise AI Security / Governance)?
